

ResolvX

Cryptography & Key Management Policy

Topic-Specific Policy - Cryptographic Standards & Key Lifecycle

POL-021 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-021
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	Head of Cloud Ops
Approver	CISO
Review Cycle	Annual, or upon material cryptographic standard change
Next Review	Q3 2027
Frameworks	ISO 27001:2022 A8.24 · NIST CSF 2.0 PR.DS-01, PR.DS-02 · SOC 2 CC6.1, CC6.7

1. Purpose

This Cryptography & Key Management Policy establishes the cryptographic standards ResolvX uses to protect data at rest and in transit, and how the keys underlying that protection is generated, stored, rotated, and retired.

References to encryption already exist across several policies, POL-004 requires AES-256 and TLS 1.3 for Restricted-tier data, POL-009 requires backup encryption, and POL-012 sets a rotation cadence for service credentials. This policy is the single authoritative source for the standards behind those references, so the specific algorithm, key length, and lifecycle requirements live in one place rather than being redefined slightly differently each time encryption comes up elsewhere.

2. Scope

This policy applies to all use of cryptography across ResolvX's systems, including:

- Data at rest (databases, object storage, backups).
- Data in transit (internal service-to-service traffic, external API traffic, client-facing connections).
- Application-level use of cryptographic functions (hashing, signing, token generation).
- Encryption keys, certificates, and the systems that manage them (AWS KMS, AWS Secrets Manager, 1Password).

3. Approved Cryptographic Standards

Use Case	Standard	Minimum
Data at rest	AES	AES-256
Data in transit	TLS	TLS 1.2 minimum; TLS 1.3 preferred for all new connections
Password hashing	Adaptive hashing function	bcrypt or Argon2, never a general-purpose hash (e.g., SHA-256 alone) for password storage
General-purpose hashing	SHA-2 family	SHA-256 minimum
Asymmetric encryption / signing	RSA or ECC	RSA-2048 minimum, or ECC P-256 minimum

MD5, SHA-1, DES, 3DES, and RC4 are not approved for any use, including legacy compatibility, without a documented, CISO-approved exception with a defined remediation date.

4. Key Management Lifecycle

Stage	Standard
Generation	Keys are generated within AWS KMS or 1Password and are never generated manually or by an application's own code.
Storage	Infrastructure and data encryption keys reside in AWS KMS; application secrets and credentials reside in AWS Secrets Manager or 1Password, per POL-012 §3.
Rotation – infrastructure / master keys	Annual, or immediately upon suspected compromise.
Rotation - service accounts, API keys	90 days, per POL-012 §6.
Revocation	Immediate upon suspected compromise, personnel offboarding with prior key access, or contract end for a vendor-issued key.
Destruction	Per POL-020, a destroyed key renders data encrypted with it permanently unrecoverable (crypto-shredding), and is treated as a valid destruction method for media where physical destruction or direct deletion isn't practical.

5. Key Access Control

Access to KMS master keys and root secrets is restricted to the minimum set of roles that require it operationally such as the Head of Cloud Ops and DevSecOps for infrastructure keys, with no standing individual access to raw key material outside those roles.

- No single individual holds unilateral authority to delete a production KMS key. Key deletion requires a second approver, consistent with the break-glass dual-control principle already established in POL-012 §5.
- Key access is included in the quarterly access review already required under POL-003.

6. Certificate Management

TLS certificates are issued through AWS Certificate Manager wherever the deployment target supports it, providing automated renewal rather than relying on manual tracking. Where a certificate must be manually managed, Head of Cloud Ops maintains an expiry monitoring alert at 30 days before expiration . An expired certificate causing a client-facing outage is treated as a preventable failure, not an unavoidable one.

7. Prohibited Practices

- No custom or homegrown cryptographic implementations, per POL-018 §4, only vetted standard libraries are used.
- No hardcoded keys, secrets, or credentials in source code, configuration files, or documentation, per POL-018 §3 and POL-012 §3.
- No use of a deprecated algorithm listed in §3 without a documented, time-limited CISO exception.

8. Roles & Responsibilities

8.1 Head of Cloud Ops

- Owns this policy and administers AWS KMS.
- Maintains certificate expiry monitoring (§6).

8.2 DevSecOps

- Ensures application code uses only approved cryptographic standards (§3) and vetted libraries (§7).

8.3 CISO

- Approves any exception to §3 or §7.

9. Compliance and Enforcement

Use of a deprecated algorithm, a hardcoded credential, or a custom cryptographic implementation found outside an approved exception is treated as a control deficiency and logged in the Corrective Action Plan.

10. Document Control

Policy ID	POL-021
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	Head of Cloud Ops
Approver	CISO
Review Cycle	Annual, or upon material cryptographic standard change
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 A8.24 · NIST CSF 2.0 PR.DS-01, PR.DS-02 · SOC 2 TSC CC6.1, CC6.7
Related Documents	POL-003 (Access Control Policy), POL-004 (Data Classification Policy), POL-009 (Backup & Recovery Policy), POL-012 (Password Policy), POL-018 (SSDLC Policy), POL-020 (Data Destruction Policy)

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		